CISM engagement report — 172.28.0.3

- Run: `afea37ce560c4504b3c4dd232566f7ea`
- Generated: 2026-10-18T20:25:32+00:00
- Outcome: did not complete cleanly — 0 tool call(s), 0 failure(s), 0 guardrail block(s), 6 extraction fallback(s)

Phase progression

- `2026-10-18T19:37:15+00:00` → **recon**
- `2026-10-18T19:37:45+00:00` → **enumeration**
- `2026-10-18T19:39:09+00:00` → **vulnerability-discovery**
- `2026-10-18T20:09:33+00:00` → **exploitation**

Findings

[resolved] open-port — 172.28.0.3 (80/tcp)

- `19:37:38` **nmap** [T2]: 80/tcp http

[resolved] open-port — 172.28.0.2 (21/tcp)

- `19:38:30` **nmap** [T2]: 21/tcp ftp
- `20:08:27` **nmap** [T2]: 21/tcp ftp

[resolved] open-port — 172.28.0.2 (22/tcp)

- `19:38:30` **nmap** [T2]: 22/tcp ssh
- `20:08:27` **nmap** [T2]: 22/tcp ssh

[resolved] open-port — 172.28.0.2 (23/tcp)

- `19:38:30` **nmap** [T2]: 23/tcp telnet
- `20:08:27` **nmap** [T2]: 23/tcp telnet

[resolved] open-port — 172.28.0.2 (25/tcp)

- `19:38:30` **nmap** [T2]: 25/tcp smtp
- `20:08:27` **nmap** [T2]: 25/tcp smtp

[resolved] open-port — 172.28.0.2 (111/tcp)

- `19:38:30` **nmap** [T2]: 111/tcp rpcbind
- `20:08:27` **nmap** [T2]: 111/tcp rpcbind

[resolved] open-port — 172.28.0.2 (139/tcp)

- `19:38:30` **nmap** [T2]: 139/tcp netbios-ssn
- `20:08:27` **nmap** [T2]: 139/tcp netbios-ssn

[resolved] open-port — 172.28.0.2 (445/tcp)

- `19:38:30` **nmap** [T2]: 445/tcp microsoft-ds
- `20:08:27` **nmap** [T2]: 445/tcp netbios-ssn

[resolved] open-port — 172.28.0.2 (512/tcp)

- `19:38:30` **nmap** [T2]: 512/tcp exec
- `20:08:27` **nmap** [T2]: 512/tcp exec?

[resolved] open-port — 172.28.0.2 (513/tcp)

- `19:38:30` **nmap** [T2]: 513/tcp login
- `20:08:27` **nmap** [T2]: 513/tcp login

[resolved] open-port — 172.28.0.2 (514/tcp)

- `19:38:30` **nmap** [T2]: 514/tcp shell
- `20:08:27` **nmap** [T2]: 514/tcp tcpwrapped

[resolved] web-fingerprint — 172.28.0.3 (302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php])

- `20:08:27` **whatweb** [T2]: http://172.28.0.3: 302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php]

[resolved] web-fingerprint — 172.28.0.3 (200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*])

- `20:08:27` **whatweb** [T2]: http://172.28.0.3/login.php: 200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]

[resolved] server-banner — 172.28.0.3 (Apache/2.4.25 (Debian))

- `20:10:17` **nikto** [T2]: Server: Apache/2.4.25 (Debian)

[resolved] nikto-finding — 172.28.0.3 ([600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).)

- `20:10:17` **nikto** [T2]: [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

[resolved] nikto-finding — 172.28.0.3 ([013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)

- `20:10:17` **nikto** [T2]: [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

[resolved] nikto-finding — 172.28.0.3 ([013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options)

- `20:10:17` **nikto** [T2]: [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options

[resolved] nikto-finding — 172.28.0.3 ([013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy)

- `20:10:17` **nikto** [T2]: [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

[resolved] nikto-finding — 172.28.0.3 ([013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi)

- `20:10:17` **nikto** [T2]: [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi

[resolved] nikto-finding — 172.28.0.3 ([013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy)

- `20:10:17` **nikto** [T2]: [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

[resolved] nikto-finding — 172.28.0.3 ([750500] /config/: Directory indexing found. See: CWE-548)

- `20:10:17` **nikto** [T2]: [750500] /config/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.3 ([000998] /config/: Configuration information may be available remotely.)

- `20:10:17` **nikto** [T2]: [000998] /config/: Configuration information may be available remotely.

[resolved] nikto-finding — 172.28.0.3 ([750500] /docs/: Directory indexing found. See: CWE-548)

- `20:10:17` **nikto** [T2]: [750500] /docs/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.3 ([003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/)

- `20:10:17` **nikto** [T2]: [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

[resolved] nikto-finding — 172.28.0.3 ([006333] /login.php: Admin login page/section found.)

- `20:10:17` **nikto** [T2]: [006333] /login.php: Admin login page/section found.

[resolved] nikto-finding — 172.28.0.3 ([007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.)

- `20:10:17` **nikto** [T2]: [007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.

[resolved] nikto-finding — 172.28.0.3 ([007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://)

- `20:10:17` **nikto** [T2]: [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://

[resolved] nikto-finding — 172.28.0.3 ([007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t)

- `20:10:17` **nikto** [T2]: [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t

[resolved] exposed-path — 172.28.0.3 (/docs (301))

- `20:15:55` **gobuster** [T2]: /docs (301)

[resolved] exposed-path — 172.28.0.3 (/robots.txt (200))

- `20:15:55` **gobuster** [T2]: /robots.txt (200)

[resolved] exposed-path — 172.28.0.3 (/config (301))

- `20:15:55` **gobuster** [T2]: /config (301)

[resolved] exposed-path — 172.28.0.3 (/phpinfo.php (302))

- `20:15:55` **gobuster** [T2]: /phpinfo.php (302)

[resolved] exposed-path — 172.28.0.3 (/setup.php (200))

- `20:15:55` **gobuster** [T2]: /setup.php (200)

[resolved] curl — 172.28.0.3/login.php (7dd4dc70656f)

- `20:16:19` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/login.php (2f4ccbca46ab)

- `20:20:41` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/login.php (218f6c2902fd)

- `20:21:46` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/login.php (7cc1d78ebb6e)

- `20:23:43` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

Other observed activity (not resolved)

[blocked] dead-region — 172.28.0.3/login.php (pruned:172.28.0.3/login.php:curl:172.28.0.3/login.php:727d3bf103e1+sql-injection-attempt:172.28.0.3/login.php:no-injection-found)

- `20:19:04` **prune** [T3]: collapsed 2 dead nodes: pruned:172.28.0.3/login.php:curl:172.28.0.3/login.php:727d3bf103e1, sql-injection-attempt:172.28.0.3/login.php:no-injection-found

[contested] curl — 172.28.0.3/login.php (2d5433890360)

- `20:20:08` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

Narrative context

- `[T2]` (recon) 80/tcp http
- `[T3]` (recon) I'll begin the PTES engagement with reconnaissance. Let me start by scanning both in-scope targets to identify open serv
- `[T2]` (recon) phase proposal → enumeration (pending /phase approval)
- `[T2]` (enumeration) 21/tcp ftp
- `[T2]` (enumeration) 22/tcp ssh
- `[T2]` (enumeration) 23/tcp telnet
- `[T2]` (enumeration) 25/tcp smtp
- `[T2]` (enumeration) 111/tcp rpcbind
- `[T2]` (enumeration) 139/tcp netbios-ssn
- `[T2]` (enumeration) 445/tcp microsoft-ds
- `[T2]` (enumeration) 512/tcp exec
- `[T2]` (enumeration) 513/tcp login
- `[T2]` (enumeration) 514/tcp shell
- `[T3]` (enumeration) I'll continue the enumeration. Let me start with a full port scan on Metasploitable2 (172.28.0.2) to identify all its op
- `[T2]` (enumeration) phase proposal → vulnerability-discovery (pending /phase approval)
- `[T2]` (vulnerability-discovery) http://172.28.0.3: 302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php]
- `[T2]` (vulnerability-discovery) http://172.28.0.3/login.php: 200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux]

[Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]

- `[T3]` (vulnerability-discovery) I'll run version detection on Metasploitable2's open services and fingerprint the DVWA web app in parallel.
- `[T2]` (vulnerability-discovery) phase proposal → exploitation (pending /phase approval)
- `[T2]` (exploitation) Server: Apache/2.4.25 (Debian)
- `[T2]` (exploitation) [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
- `[T2]` (exploitation) [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- `[T2]` (exploitation) [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
- `[T2]` (exploitation) [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
- `[T2]` (exploitation) [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi
- `[T2]` (exploitation) [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
- `[T2]` (exploitation) [750500] /config/: Directory indexing found. See: CWE-548
- `[T2]` (exploitation) [000998] /config/: Configuration information may be available remotely.
- `[T2]` (exploitation) [750500] /docs/: Directory indexing found. See: CWE-548
- `[T2]` (exploitation) [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
- `[T2]` (exploitation) [006333] /login.php: Admin login page/section found.
- `[T2]` (exploitation) [007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.
- `[T2]` (exploitation) [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://
- `[T2]` (exploitation) [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t
- `[T3]` (exploitation) ToolExecutionError: gobuster exited 1

Error: unknown shorthand flag: 'i' in -ir

- `[T3]` (exploitation) blocked by action guardrail
- `[T3]` (exploitation) I'll run nikto and gobuster against DVWA, and dig into Metasploitable2's services in parallel.
- `[T3]` (exploitation) ToolExecutionError: gobuster exited 1

Error: error on parsing arguments: wordlist file "/usr/share/wordlists/seclists/Di

- `[T3]` (exploitation) The wordlist path doesn't exist. Let me try the common alternative location for seclists.

- `[T2]` (exploitation) /docs (301)
- `[T2]` (exploitation) /robots.txt (200)
- `[T2]` (exploitation) /config (301)
- `[T2]` (exploitation) /phpinfo.php (302)
- `[T2]` (exploitation) /setup.php (200)
- `[T3]` (exploitation) You're right, let me call gobuster with no extra argument.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) I'll test DVWA with the default credentials (admin/admin).
- `[T3]` (exploitation) The login failed (form re-displayed). Let me try the classic DVWA SQL injection bypass with the user_token parameter.
- `[T3]` (exploitation) Let me try sqlmap on the DVWA login form for injection testing.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) Let me try a cleaner SQL injection payload.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) The form re-displayed, meaning the injection didn't authenticate. Let me try with the user_token included and a proper S
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) The form keeps re-displaying. Let me try the classic DVWA SQLi payload with a single quote truncation.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...